AI in Cybersecurity for a Financial Services Company

Project Report

Submitted to: Mr. Chintan Patel

Submitted by: Khushi Shah
Id Number: 20262003

1. Executive Summary

A major player in the Indian financial services space is selling trust. Trust in the fact that customer ids, account details and payment information is safe. Trust in the fact that regulators would believe that the company can pick up and report an attack quickly. When the threat is discovered too late, alerts are left unread and responses involve manual steps. The effect of late discovery is stolen customer data, frozen services, regulatory fines, loss of customers. Here's an AI strategy that is designed for such a scenario, using Quick Heal, Palo Alto and Microsoft only as a reference case of organizations that have solved similar problems.

Thus I propose a "Cyber Intelligence" Programme, with the three inter-related layers of (1) real-time threat detection (2) explainable anomaly identification with risk scoring of anomalous behaviour and (3) automated response with tiered human approval. All this operating on one, governed, security-data platform and made available across 3-horizons over 36 months. I show in my illustrative business case (Appendix B) 3-year ROI of ~43% and a payback period of ~25 months. But here I emphasize that, it is not the sophistication of the models (which is in line with the course lesson that "AI implementation fails primarily because of people and process, and not technology" (Patel, 2026) but, more, the readiness of data and adoption by analysts and, guardrails of responsible AI.

2. Cybersecurity Context of Indian Financial Services (Risk & Scale)

Current challenge. The average data breach cost in India reached a new high of ₹22 crore (an increase of 13% from 2024) as per the IBM's 2025 study. The average cost for financial services sector breaches is ~ ₹28 crore (IBM India Newsroom, 2025; People Matters, 2025). The global average for the financial sector is USD 5.56M per breach (compared to the overall sector average of USD 4.44M) (Northdoor, 2025). Similarly, the number of threats is staggering. For instance, in 2025, CERT-IN has observed 570,108 incidents in the banking sector. Further, 348,607 instances have been detected in the first half of 2026. 39 targeted intrusion campaigns were also observed in 2025 (Outlook Money, 2026). These are part of the total number of incidents (more than 29.44 Lakh) managed across sectors in 2025 (Press Information Bureau, 2026). See Appendix F Figure F1 for the numbers.

Data & Alert volume. Suppose a big company. It gets logs from Endpoints, Network Devices, Identities, Email, Cloud, Applications, Core Banking. That means millions of events per day. My example -the security team gets 4000+ alerts per day. There is no way human teams can read such volume of data with good care. This is why automation is attractive. But the quality of automation matters.

Bottlenecks. The limitations of signature-based tools with new & polymorphic attacks. The limitations of static rules (e.g., alert on 5 consecutive failed logins) for slow-moving attacks using a stolen (but valid) password. Analyst fatigue. Manual containment (in mins to hours) vs. ransomware can encrypt in mins. The time factor (e.g., CERT-In needs reporting in 6 hrs. And DPDP Rules 2025 now requires reporting to Data Protection Board in 72 hrs [Matters.ai, n.d.]). But despite the known benefits, 73% of surveyed Indian organizations were found to have limited/no usage of AI and security automation (IBM India Newsroom, 2025). And the attackers are moving fast: 54% click-through rate for AI automated phishing attacks vs 12% for regular phishing attacks (Microsoft) (HapaKenya, 2025).

How I analyze. Three column notes template (Appendix E) of Industry Challenge & Context (what's the challenge in financial services in India?), AI Strategy & Mechanism (which AI tool/framework solves this?), My Analysis & Recommendations (How to implement this safely and effectively for a company). My analysis should be about 50% (50%) of the report. The course also differentiates between AI Strategy (what to build & why) and AI Execution Plan (how, when, who, sequence). Also how organizations often mix the two (Patel, 2026). I do that. Sections 3-5 is strategy and readiness for that. Sections 6-10 is for execution, people, value and risk. My measurable objectives are:

- O1: Detect & respond: Reduce mean time to detect and respond to high severity incidents. From hours/days to minutes within 36 months. Start with most critical systems.
- O2: Reduce exposure and noise. Reduce customer records per incident exposure. Reduce the number of alerts requiring human review. By at least half.
- O3: Comply with - Notify all reportable incidents within 6 hours (Cert-In), 72 hrs (DPDP). With audit evidence.
- O4 - Trustworthy AI: no unexplained adverse automated actions; all models pass before-and-after launch accuracy, bias and security audits.

3. Reference Cases: Lessons from Similar Organisations

This report is not about any particular company, it's about the problem. The use of 3 organisations is just as a reference point since each one attacked a different aspect of a similar problem. All numbers are from public disclosures and company results and should be considered as indicative. Sources of data are shown in the references. A comparison table is shown in appendix A.

Quick Heal (India): Consumer and, under the brand Seqrite, enterprise security provider based in Pune. They claim that their AI engine (GoDeep.AI) is a deep-learning technology that identifies and prevents known and unknown threats in real-time (Seqrite, n.d.). They won certification for Seqrite Endpoint Security in corporate endpoint protection tests in AV-TEST in 2024 (Seqrite, 2024). Q1 FY27 revenue at ₹45.0 crore, -21.4% YoY (enterprise revenue of ₹30.0 crore, and -39.3% YoY consumer revenue). Management expects to increase from >50% of revenue to 80-90% in 2-3 years from the enterprise segment. They announced a new Seqrite XDR customer in banking technology (CXO Today, 2026; Arthneeti, 2026). Lesson: Indian vendor can provide local knowledge of threats, BFSI focus, DPDP-aligned services for a lower price but need due diligence around product depth and integration for a company in transition.

Palo Alto Networks (Global): Palo Alto Networks reported that its 4Q of fiscal 2026 had revenues of USD 3.41b (+34%) and Next-Generation Security annual recurring revenue of USD 9.10b

4. Proposed AI Strategy

4.1 Real-time threat detection

My detection layer is built on behaviour, not only on known fingerprints. It scores activity within seconds across five sources: (1) endpoint models that watch what a program does, such as mass file encryption, injection into other processes or deletion of backups, and stop it mid-execution, which is the main defence against ransomware; (2) network analytics that learn normal traffic and flag command-and-control beaconing and bulk data transfers, including inside encrypted traffic by studying metadata; (3) email models that use language and image analysis to catch phishing and spoofed brands; (4) identity risk scoring that rates every sign-in on device, location, time and history and triggers step-up authentication or a block; and (5) threat-intelligence matching, so that a newly published indicator is checked against months of the firm’s own logs immediately.

Guardrails are built in. Monitoring is limited to security-relevant data. Models are trained and tested on confirmed incidents and red-team simulations, not only on past alerts, so that they do not inherit the blind spots of the old rules, and historic incidents are replayed to check whether they would have been caught. High-impact detections are confirmed by a human analyst before any disruptive action.

4.2 Anomaly identification

The anomaly layer builds a baseline of normal behaviour for every user, device, application and account, and flags deviations. I start with interpretable methods and add stronger ones: isolation forests for unlabelled outliers (Liu et al., 2008), autoencoders, gradient-boosted trees where labelled attacks exist, and graph analytics to expose chains of mule accounts and fraud rings across UPI, NEFT and cards. Inputs include logins per hour, files opened per session, data volume sent out, privilege changes, impossible-travel signals and payment velocity. Protected attributes are not used.

The core design is risk-based scoring. In an illustration, a new device adds 30 points, a 2 a.m. login adds 20, a privilege change adds 25 and a bulk download of 4,000 records adds 35. The firm asks for extra authentication at 70 points and locks the account at 100. No single sign passes 70, so a fixed rule stays silent, but together they reach 110. Two design choices follow from the course’s failure modes. First, to avoid metrics mismatch, I judge the models on precision and recall for confirmed incidents and on false positives per analyst, not on accuracy, because attacks are rare and a model that says “nothing is wrong” is highly “accurate” but useless. Second, every alert comes with its main drivers (using SHAP-style explanations; Lundberg & Lee, 2017), such as “new device, 4,000 records, outside working hours”, so that analysts can verify it in seconds. Baselines are used for security only, never for staff performance decisions.

4.3 Automated response with tiered human control

Detection has value only if action follows quickly. Security orchestration, automation and response (SOAR) playbooks isolate infected devices, force password resets, revoke sessions, block malicious domains everywhere, remove phishing emails from all mailboxes and open a ticket containing the evidence trail, timeline and affected-data summary, so the CERT-In and DPDP notices can be drafted within hours. Automation is bounded by tiers (Appendix F, Figure F3): low-risk, high-confidence actions run automatically; medium-risk actions, such as isolating a production server, need a one-click analyst approval; and high-impact actions, such as halting the payment gateway, always need senior sign-off. A generative-AI copilot summarises incidents, writes search queries and proposes next steps, but its output is verified against evidence before action. This follows the course idea of augmented intelligence: AI enhances the analyst's judgement and speed rather than replacing it (Patel, 2026).

Illustration. At 2:07 a.m. a loan officer's stolen password is used from a new laptop. A rule-based tool sees a valid login and stays silent, and the intruder can stay hidden for days (Appendix F, Figure F4). In my design the anomaly layer combines the new device, the odd hour, a privilege change and a 4,000-record download into a score above the lock threshold; by 2:09 a.m. the session is revoked and the account is locked, and a ticket with the evidence is waiting for the morning analyst. The same logic applies to ransomware on a Friday evening, where behavioural detection and automatic isolation limit the damage to one laptop instead of a whole branch network.

4.4 Technology foundation and emerging trends

The three layers share one security-data platform that connects endpoint, identity, email, cloud, application and core-banking logs under one user and asset identifier, with a SIEM/XDR layer, a feature store, a model registry and ML operations tooling (Appendix F, Figure F2). For commodity capabilities such as endpoint protection, email security, SIEM and SOAR I would buy or partner, using the reference vendors as a shortlist and requiring data residency in India, audit rights and exit clauses. Differentiating assets, such as the firm's own baselines, fraud models and playbooks, should be built in-house because they depend on its customers and systems.

Three emerging trends from the course shape the design (Patel, 2026). Agentic AI, such as Palo Alto's agentic additions to its Cortex platform and the Security Copilot agents, can investigate alerts and propose fixes, so I allow it only inside approval gates. Small language models and on-device AI are preferred for routine tasks such as ticket drafting and log summaries, which lowers cost and keeps sensitive logs inside the firm. Sustainable AI pushes me to right-size models instead of defaulting to the largest one. A fourth point is specific to this topic: the AI itself must be secured. Shadow AI added about ₹17.9 million to the average Indian breach, and only 37% of Indian organisations had AI access controls (IBM India Newsroom, 2025), so my plan includes an AI inventory, access controls and testing against prompt injection and data poisoning.

4.5 Protecting customer data directly

Detection reduces the chance and duration of an incident, but data-level controls decide how much an attacker can take. The platform therefore includes encryption at rest and in transit, tokenisation of card, account and national-ID numbers, data-loss prevention on exports and uploads, Zero Trust access that re-checks every user and device using the risk scores from the first two layers, segmentation around core banking and payment systems, and immutable backups that ransomware cannot encrypt. For customers, in-app risk warnings, scam-call and malicious-link detection (the purpose of tools such as Quick Heal's AntiFraud.AI) and out-of-band confirmation of unusual high-value transfers close the gap that deepfake voice and AI-written scams exploit.

5. AI Readiness Assessment

Before building any solution, the course calls for assessing the three dimensions of readiness (Patel, 2026). On data readiness, security logs are scattered across tools, asset and user identifiers are unaligned, and confirmed breaches are rare, making labelled examples scarce. On talent readiness, a financial firm will have decent network and infrastructure engineers but inadequate detection engineers, data scientists and responsible-AI practitioners. On process readiness, incident classification, escalation paths and playbooks need to be documented well enough for automation to follow them, and the six-hour and 72-hour reporting steps need to be rehearsed. The course warns of overestimating maturity and that data pipelines, not models, are the source of most scaling failures. I therefore grade the company at "developing" maturity on all three (a

hypothesis to be tested) and recommend an eight-week readiness sprint, summarised in Appendix D, before any large investment.

6. Implementation Roadmap

Following the three-horizon structure from the course, each horizon has milestones, owners and success metrics, which prevents endless pilots (Patel, 2026). Appendix C summarises them.

Horizon 1 – quick wins (0–6 months): build trust with visible results. Run the readiness sprint; enforce multi-factor authentication and least privilege; centralise logs from identity, email, endpoint and core banking; set baselines for detection and response times; pilot behavioural endpoint protection, identity risk scoring and anomaly models in monitor-only mode on two critical systems; rehearse the six-hour reporting drill. Owner: CISO (sponsor) and Head of the security operations centre. Metrics: at least 90% of critical systems feeding the platform, baselines published, and 100% on-time reporting in drills.

Horizon 2 – core transformation (6–18 months): deploy at scale. Extend AI detection to all critical systems; switch on low-risk automation, then approval-gated actions; build playbooks for the ten commonest incident types; introduce the analyst copilot; add payment-fraud and graph analytics. Owner: security operations with the CIO/CTO. Metrics: reduction in time to detect and respond on live systems, share of incidents contained automatically, and alerts needing review down by half.

Horizon 3 – strategic differentiation (18–36 months): build what competitors cannot copy. Add customer-side protection such as scam alerts and in-app warnings; partner-behaviour baselines that restrict a supplier's access automatically when it departs from normal, tested agentic response inside approval gates; protection for the firm's own AI systems; an annual external audit. Owner: Executive committee. Metrics: sustained reduction in records exposed per incident, lower fraud losses, and audit and regulatory readiness.

7. Stakeholder and Change Management

The course lists five stakeholder groups with different concerns, warning that a strategy that convinces the CEO but not middle management will die quietly (Patel, 2026). Appendix D maps out each group on an influence–interest grid. The Board and CEO want risk reduction and regulatory comfort; the plan provides them with one hard ROI number and a risk dashboard. The CFO wants payback and budget control; the plan reports payback and uses stage-gated funding. The CIO/CTO and IT teams care about integration and uptime; the plan uses shared platform standards and agreed change windows. Security operations leads and business heads are the decision-makers: the plan provides alerts, drivers and playbooks in their workflow, trains them, and includes adoption in their goals. Frontline staff and customers worry about monitoring and false blocks; the plan explains what data is used, offers a review route and states that AI does not decide discipline. Legal and the Data Protection Officer are high-influence, lower-interest stakeholders who must be kept satisfied with early review.

Change follows Kotter's eight steps (Kotter, 1996; Patel, 2026): create urgency using breach-cost figures; build a coalition of the CISO, CIO, CFO and business heads; form a vision of "AI helps analysts stop attacks before customer data leaves"; communicate repeatedly; remove barriers such as slow data access; create short-term wins in Horizon 1; sustain momentum; and anchor the practice in goals and culture. The most important early step is to find respected champions, such as senior analysts and branch IT leaders, who advocate visibly amongst their peers. Level-1 analysts may fear replacement, so the plan reskills them into threat hunters and AI supervisors who validate alerts and tune playbooks.

8. ROI and Business Case

I use the course formula, ROI = (Benefit − Cost) ÷ Cost × 100, and present the three layers a board expects (Patel, 2026). Hard ROI is mainly avoided breach, fraud and downtime losses and security-operations productivity. Soft ROI includes analyst time saved, faster decisions and reduced burnout. Strategic ROI includes customer trust, regulatory readiness and proprietary security data. Following the course advice, I lead with one hard number, support with soft benefits and close with strategic value.

The illustrative model in Appendix B assumes a large financial services company with expected cyber-related losses (breach response, fraud, downtime, penalties and legal costs) of ₹150 crore a year and a security-operations cost of ₹20 crore a year. At full run-rate, AI-supported detection and response cuts expected losses by 25% (about ₹38 crore) and trims operations cost by 40% (₹8 crore). As a cross-check, IBM India found that extensive AI and automation saved about ₹3.1 crore per breach (People Matters, 2025), which would

equal about ₹37 crore a year if the firm suffers about twelve breach-class incidents. Total hard benefits over three years are about ₹93 crore against programme costs of ₹65 crore, giving an ROI of about 43% and a payback of about 25 months. I deliberately show a modest, honest return, and these figures are assumptions for demonstration that must be replaced with the company's own loss and cost data before any real decision.

9. Responsible AI, Governance and Risk

Security AI watches people and can block customers, so responsible AI is a design requirement. I apply the course's principles directly: fairness (proportionate, non-discriminatory flagging, excluded attributes), transparency (reasons shown for each score), accountability (a named business owner for each model), privacy (data minimisation and purpose limits), safety (tiered autonomy, kill switch), human oversight (people own high-impact decisions) and sustainability (right-sized models).

Governance follows the course framework: a Responsible-AI Committee with the CISO, CIO, Risk, Compliance, Legal/DPO, internal audit and an employee representative; written AI policy and guidelines; risk assessment before each launch; audit and monitoring of deployed models; and training for analysts and managers. Regulation reinforces this. The Reserve Bank of India's FREE-AI report of August 2025 sets seven guiding principles and 26 recommendations, including strengthening AI-related cybersecurity, using AI tools for threat detection and response, and an AI-incident reporting framework (Securiti, 2025; Legal500, 2025). The DPDP Act, 2023 and the Rules notified in 2025 require security safeguards and a 72-hour report to the Data Protection Board, with the full enforcement window running to May 2027 (Matters.ai, n.d.), while CERT-In's six-hour rule continues to apply (Outlook Money, 2026). Appendix E lists the five risk categories from the course with security-specific examples and mitigations.

10. Failure Modes and How to Avoid Them

The course names six ways AI projects go wrong (Patel, 2026). Data poverty: confirmed breaches are rare events, so the plan starts with behaviour baselines and red-team simulations, enriches data carefully and uses vendor intelligence. Pilot purgatory, the most dangerous mode: every pilot has a named owner, a go-live criterion and a decision date, so the firm does not feel it is "doing AI" while only running experiments. Scope creep: each horizon has a fixed scope and a change-control process. Shadow AI: analysts could paste logs or customer data into unofficial AI tools, so the plan provides approved, fast tools and clear rules. Metrics mismatch: the plan measures time to detect and respond, incidents contained and false positives, not model accuracy. Leadership abandonment: the plan uses a steering group instead of a single sponsor so that the programme survives changes in leadership.

11. Conclusion and Recommendations

AI can help a large financial services company detect threats as they happen, notice abnormal behaviour and contain incidents in seconds, but only if it is treated as a business and people programme rather than a model-building exercise. I recommend that the company: (1) start with an eight-week readiness sprint and one hard ROI target; (2) fix identity and logging first, then launch AI detection and anomaly scoring in monitor-only mode in Horizon 1; (3) make security-operations leads and business heads the centre of the adoption plan; (4) establish the Responsible-AI Committee and the audit process before the first automated action goes live, and secure the AI systems themselves; and (5) give every pilot an owner and a go-live decision date to avoid pilot purgatory

References:

1. Arthneeti — https://www.arthneeti.com/insights/quick-heal-tech-q1-fy27-earnings
2. CXO Today — https://cxotoday.com/media-coverage/quick-heal-technologies-limited-reports-q1-fy27-results/
3. ETCentric — https://etcentric.org/?p=191776
4. HapaKenya — https://hapakenya.com/2025/10/22/new-microsoft-report-shows-how-ai-is-turbocharging-cybercrime-in-africa
5. IBM India Newsroom — https://in.newsroom.ibm.com/2025-08-07-India-Records-Highest-Average-Cost-of-a-Data-Breach-IBM
6. Harvard Business School Press — Leading Change (no link provided)
7. Legal 500 — https://www.legal500.com/developments/thought-leadership/rbis-free-ai-framework-navigating-the-legal-and-regulatory-landscape/
8. IEEE — https://doi.org/10.1109/ICDM.2008.17
9. NeurIPS — https://proceedings.neurips.cc/paper/2017/hash/8a20a8621978632d76c43dfd28b67767-Abstract.html
10. Matters.ai — https://www.matters.ai/article/dpdp-breach-notification
11. Microsoft — https://microsoft.com/MDDR
12. Northdoor — https://www.northdoor.co.uk/?p=35370
13. Outlook Money — https://www.outlookmoney.com/news/banking-and-healthcare-sectors-saw-over-97-lakh-cyber-incidents-parliament
14. Palo Alto Networks — https://www.paloaltonetworks.com/company/press/2026/palo-alto-networks-reports-fiscal-fourth-quarter-and-fiscal-year-2026-financial-results
15. Patel, C. — Lecture slides (no link provided)
16. People Matters — https://www.peoplematters.in/news/ai-and-emerging-tech/indias-data-breach-cost-jumps-to-indian-rupee22-crore-highest-on-record-ibm-42381
17. Press Information Bureau — https://static.pib.gov.in/WriteReadData/specificdocs/documents/2026/jan/doc2026123764501.pdf
18. Securiti — https://securiti.ai/?p=100951
19. Seqrite — https://www.seqrite.com/newsroom/seqrite-endpoint-security-achieves-prestigious-av-test-corporate-endpoint-protection-certification-demonstrating-excellence-in-enterprise-security/
20. Seqrite — https://www.seqrite.com/blog/anti-virus-scan-engine/
21.TechMarketView —https://www.techmarketview.com/ukhotviews/archive/2026/09/02/palo-alto-rides-ai-tailwinds-to-record-q4
22.Zacks — https://www.zacks.com/stock/news/2986417/panws-xsiam-arr-surges-70-in-q4-fy26-can-the-momentum-continue

Appendix A – Reference Cases Comparison

Organisation	Scope	Public AI / security practice	Lesson applied in my design
Quick Heal / Seqrite	India, endpoint and enterprise security	GoDeep.AI engine; AV-TEST certified endpoint product; Q1 FY27 revenue ₹45.0 crore (−21.4%), enterprise ₹30.0 crore; new XDR customer in banking technology	Local threat knowledge, BFSI and DPDP focus; check integration depth and vendor stability
Palo Alto Networks	Global, security platforms	FY26 Q4 revenue USD 3.41 billion (+34%); NGS ARR USD 9.10 billion (+63%, incl. acquisitions); XSIAM above USD 700 million ARR; Prisma AIRS above USD 100 million ARR	Consolidate data, detection and automation on one platform; secure the firm's own AI
Microsoft	Global, cloud and identity ecosystem	100 trillion signals a day; 4.5 million new malware blocks daily; 38 million identity-risk detections a day; Security Copilot with 11 agents	Identity-centred risk scoring; threat intelligence at scale; analyst copilot with human review

Appendix B – Illustrative ROI Model (₹ crore)
Assumptions: expected cyber-related losses of ₹150 crore a year; security-operations cost of ₹20 crore a year; at full run-rate losses fall by 25% and operations cost by 40%. All figures are illustrative.

Item	Year 1	Year 2	Year 3	Total
Avoided cyber-related losses	10	30	38	78
Security-operations efficiency	2	5	8	15
Total hard benefit	12	35	46	93
Programme cost (platform, data, talent, change, governance)	28	20	17	65
Net benefit	−16	15	29	28
Cumulative net benefit	−16	−1	28	–

ROI = (93 − 65) ÷ 65 × 100 ≈ 43%. Payback: the cumulative deficit of 1 at the end of year 2 is recovered about half a month into year 3, so payback is about 25 months.

Appendix C – Roadmap Metrics Summary

Horizon	Window	Focus	Success metrics
1 – Quick wins	0–6 months	Readiness sprint, MFA and least privilege, central logging, monitor-only pilots on two critical systems, reporting drill	≥90% critical-system log coverage; baselines published; 100% on-time reporting in drills
2 – Core transformation	6–18 months	AI detection at scale, low-risk then approval-gated automation, ten playbooks, analyst copilot, payment-fraud analytics	Lower time to detect and respond; share auto-contained; alerts needing review −50%

Horizon	Window	Focus	Success metrics
3 – Strategic differentiation	18–36 months	Customer-side protection, partner baselines, agentic response inside gates, AI-system security, external audit	Fewer records exposed per incident; lower fraud losses; audit readiness

Appendix D – Readiness Assessment and Stakeholder Map

Readiness dimension	Key question	Likely status	First action
Data	Do we have complete, linked and accessible security logs?	Developing: scattered tools, mismatched identifiers, few labelled incidents	Build log catalogue and common user and asset identifiers
Talent	Can we build, deploy and maintain the models and playbooks?	Developing: few detection engineers and responsible-AI specialists	Hire and train; partner for audits and managed detection
Process	Are incident, escalation and reporting steps documented and rehearsed?	Developing: playbooks vary by unit	Standardise incident classes and run reporting drills

Stakeholder	Main concern	Influence / interest	Approach
Board / CEO	Risk and regulation	High / high	Manage closely: one hard ROI number, risk dashboard
CFO	Payback and budget	High / high	Manage closely: stage-gated funding
CIO / CTO / IT	Integration, uptime	High / high	Manage closely: shared platform standards, change windows
SOC leads and business heads	Workload and relevance	High / high	Manage closely: embed in workflow, train, measure adoption
Legal and DPO	Compliance	High / low	Keep satisfied: early review
Frontline staff and customers	Privacy, false blocks	Low / high	Keep informed: transparency, review route, champions

Appendix E – Risk Register and Step-01 “3-Column” Note Template

Risk register

Risk category	Security-specific example	Mitigation
Technical	Model drift as attacker behaviour changes; poisoned training data; evasion of models	Quarterly testing and retraining; layered detection; red-teaming models
Ethical	Unfair flagging of certain roles, regions or working patterns; customers wrongly blocked	Proportionality checks, excluded attributes, human review route

Risk category	Security-specific example	Mitigation
Legal and compliance	Missed CERT-In six-hour or DPDP 72-hour report; non-compliance with RBI FREE-AI	Reporting drills, legal review, documentation, audit trails
Operational	A wrong automatic action takes down a payment system; tool outage	Tiered autonomy, kill switch, staged rollout, fail-safe modes
Reputational	Customer or staff backlash over monitoring or false blocks; a publicised breach	Transparent notices, opt-in features where possible, clear communication

Step-01: Set up a "3-Column" note template

Industry Challenge & Context	AI Strategy & Mechanism	My Analysis & Recommendations (50%)
Breaches cost India a record ₹22 crore on average, ₹28 crore in financial services; banking recorded 570,108 CERT-In incidents in 2025	Behavioural endpoint, network, email and identity models scoring activity in real time	Start in monitor-only mode; judge by precision, recall and false positives per analyst; keep humans on high-impact decisions
Signature tools and fixed rules miss new and slow attacks; alert fatigue	UEBA baselines, isolation forests, graph analytics, SHAP-style drivers, risk-based scoring	Explain every alert; use baselines for security only; protect privacy of staff and customers
Six-hour and 72-hour reporting duties; slow manual containment	SOAR playbooks with three autonomy tiers and an evidence-ready ticket	Automate low-risk actions first; approval for medium risk; senior sign-off for high impact
73% of Indian firms use little or no security AI; shadow AI adds cost	Governed data platform, Responsible-AI Committee, AI inventory and access controls, FREE-AI alignment	Assess readiness first; secure the AI itself; give every pilot an owner and a decision date

Appendix F – Figures

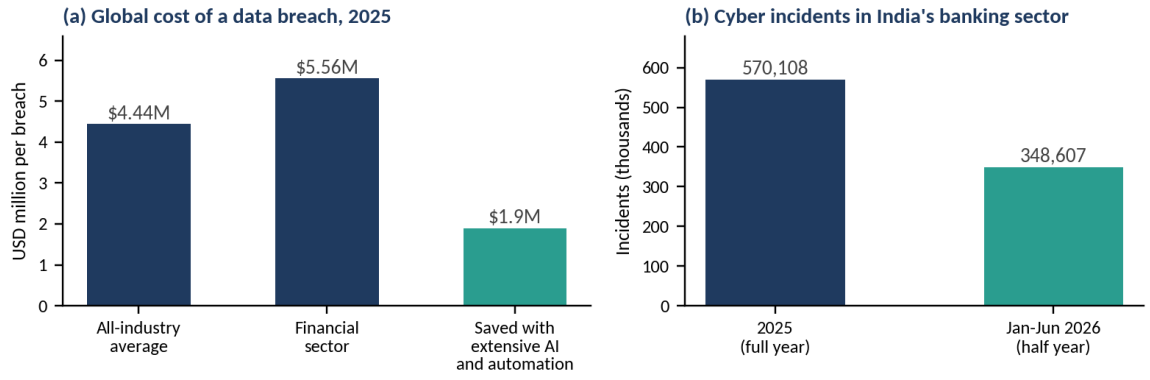


Figure F1. (a) Average global cost of a data breach, 2025; (b) cyber incidents in India's banking sector. Sources: Northdoor (2025); Outlook Money (2026).

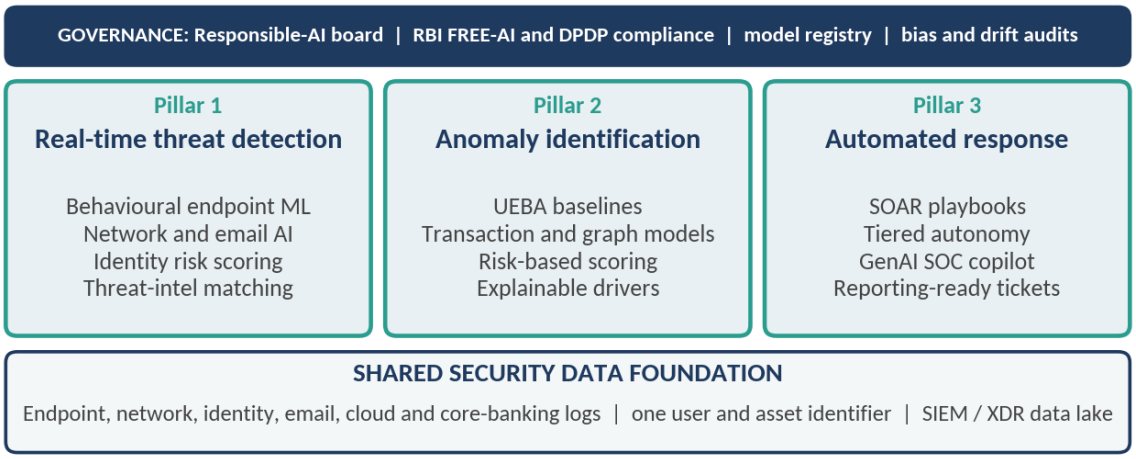


Figure F2. Proposed AI cybersecurity strategy framework (author's illustration).

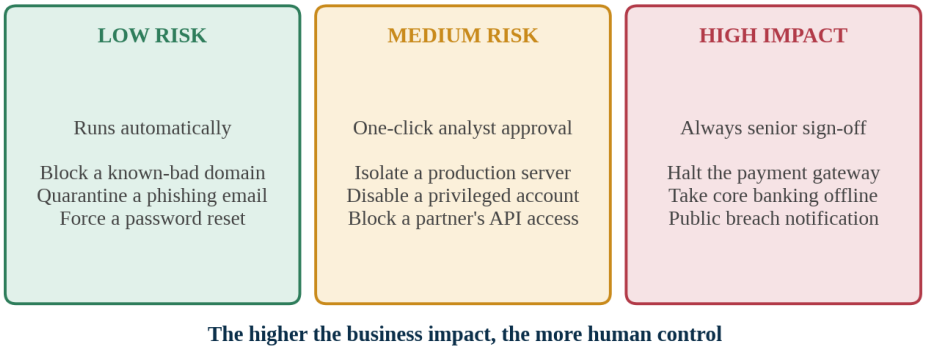


Figure F3. Tiered autonomy for automated response (author's illustration).

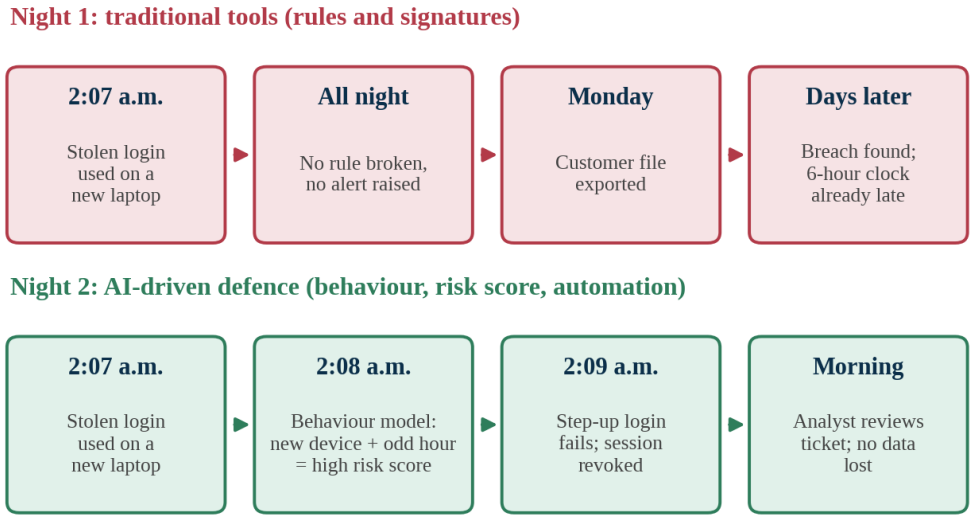


Figure F4. The same intrusion with and without AI-driven detection and response (illustrative scenario).